

Table of Contents

Cisco Secure Workload — CMMC 2.0 (Cybersecurity Maturity Model Certification)

Reference Design | Level 2 Lead, with Level 1 / Level 3 Deltas

Version: 1.0 (draft — pending SME review) | **Standard:** CMMC 2.0 (final rule effective December 16, 2024) | **Audience:** DoD contractors and subcontractors handling Federal Contract Information (FCI) or Controlled Unclassified Information (CUI) | **Environment:** Hybrid (on-prem + cloud) supporting the CUI/FCI scope

Reader's Guide

Who this is for. Defense Industrial Base (DIB) organisations that hold or are seeking DoD contracts subject to DFARS 252.204-7012 (safeguarding CUI), or to the broader DFARS 252.204-7021 CMMC clause once it appears in your contracts. The default depth in this reference design is written for **CMMC Level 2** because that's where the bulk of the technical work — and the bulk of CSW alignment — lives. Level 1 and Level 3 deltas are called out where the work materially changes.

Why CMMC and not just NIST 800-171 or 800-53? CMMC 2.0 doesn't invent new controls. It is the DoD's *certification* mechanism that your organisation has implemented the controls already required under DFARS 252.204-7012:

- **Level 1 (Foundational, 15 safeguards)** — implements the 15 basic safeguarding requirements from FAR 52.204-21. Self-attested annually. Required for any contract handling FCI.
- **Level 2 (Advanced, 110 controls)** — implements **all 110 controls of NIST SP 800-171 Rev 2**. Self-assessed (for some contracts) or third-party-assessed via a C3PAO every 3 years. Required for any contract handling CUI.
- **Level 3 (Expert, ~134 controls)** — Level 2 plus a selected subset of NIST SP 800-172 enhanced security requirements. Government-led assessment. Required for the highest-criticality contracts.

Questions this reference design helps you answer:

- *AC.L2-3.1.1 / 3.1.2 (Limit access; restrict to authorised functions): can I produce evidence that workload-level access is enforced and that segmentation between FCI/CUI scope and out-of-scope estate is real?*

- *AU.L2-3.3.1 / 3.3.2 (Audit records; CUI access traceability): can I produce per-user, per-process, per-flow audit records for every action involving a CUI-bearing workload, retained for the contract-required period?*
- *CM.L2-3.4.1 / 3.4.2 / 3.4.6 (Baseline configurations; security configuration; least functionality): can I show the baseline configuration of every CUI-scope workload, detect drift from it, and demonstrate that only necessary functions/ports/services are running?*
- *RA.L2-3.11.2 / 3.11.3 (Vulnerability scanning; remediate vulnerabilities): can I produce continuous CVE inventory per CUI-scope workload, with remediation tracking on an SLA the C3PAO will accept?*
- *SC.L2-3.13.1 / 3.13.5 / 3.13.6 (Boundary protection; deny by default; allow by exception): can I demonstrate workload-level deny-by-default with a documented allow-list, and show that the CUI scope has a defined and enforced boundary?*
- *SI.L2-3.14.1 / 3.14.6 / 3.14.7 (Identify/correct flaws; monitor for attacks; identify unauthorised use): can I show monitoring evidence at the workload level for the CUI scope, with detection rules sufficient to support the C3PAO assessment?*

What you'll need. Your current **CUI scope diagram** (the authoritative answer to "where does CUI live and through what systems does it flow?"), your current System Security Plan (SSP) and Plan of Action & Milestones (POA&M), your most recent NIST SP 800-171 self-assessment score, and your target CMMC level. CSW augments the SSP and POA&M; it does not author them.

Where to start. Section 2 if you're scoping CSW relative to the CUI boundary; sections 3–4 if AC and AU are the audit gap; section 5 if CM (configuration management) is the open item; section 6 for RA (vulnerability assessments); section 7 for SC (boundary protection); section 8 for SI (system & information integrity).

Important. CMMC 2.0 assessment is performed by a Certified Third- Party Assessor Organisation (C3PAO) for Level 2 certified-assessed scope. Nothing in this reference design substitutes for the SSP, POA&M, or the C3PAO engagement. CSW can support evidence for many technical practices the C3PAO evaluates, subject to CUI scope, implementation, and assessor judgment.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces

CSW term	Meaning	Why compliance teams care
		drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Level 2 (800-171) AC/AU/CM/RA/SC/SI family evidence
- CUI enclave labelling and scope export for SSP inputs
- Prepares POA&M items with workload-level gap visibility

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

CMMC 2.0 final rule (DFARS 252.204-7021 / 32 CFR Part 170) was published October 15, 2024 and became effective December 16, 2024. DoD contracts will phase in CMMC requirements over the subsequent three years.

The three CMMC 2.0 levels:

Level	Name	Controls	Assessment	Trigger
1	Foundational	15 (FAR 52.204-21)	Annual self-attestation	Contract handles FCI
2	Advanced	110 (NIST SP 800-171 Rev 2)	Self-assessment or C3PAO every 3 years (per contract)	Contract handles CUI
3	Expert	Level 2 + selected NIST SP 800-172 enhancements	Government-led	Highest-criticality contracts

Where CSW fits across the 14 NIST 800-171 control families (which are CMMC Level 2):

Family	Title	CSW relevance
AC	Access Control	Direct (workload-level enforcement)
AT	Awareness & Training	Out of scope (HR/training)
AU	Audit & Accountability	Direct (per-flow + per-process telemetry)
CA	Security Assessment	Supporting (continuous monitoring evidence)
CM	Configuration Management	Direct (baseline + drift)
IA	Identification & Authentication	Supporting (identity is upstream)
IR	Incident Response	Direct (evidence) (forensic reconstruction)
MA	Maintenance	Supporting
MP	Media Protection	Out of scope
PE	Physical Protection	Out of scope
PS	Personnel Security	Out of scope
RA	Risk Assessment	Direct (continuous CVE

Family	Title	CSW relevance
		+ reachability)
SC	System & Communications Protection	Direct (boundary protection, segmentation)
SI	System & Information Integrity	Direct (monitoring, detection, integrity)

CSW is direct on six families (AC, AU, CM, RA, SC, SI), supporting on four (CA, IA, IR evidence, MA), and out of scope on four (AT, MP, PE, PS).

2. CUI Scope Identification and Boundary Labelling

The **CUI scope** is the most consequential decision in a CMMC assessment. Anything in scope must implement all 110 Level 2 controls; anything out of scope is exempt. The wider the scope, the larger the certification effort.

CSW does not define the CUI boundary — that is a data-classification exercise driven by your contracts and your data flows. CSW *does* host the labels that make the boundary enforceable and auditable.

CSW Implementation:

Step 1: Get the CUI scope determination from your CUI-handling owner

→ Per workload:

```
cui_scope:      in-scope | security-protection-asset (SPA) |
                 contractor-risk-managed | out-of-scope
cui_role:       processes | stores | transmits
cmmc_level:    l1 | l2 | l3
contract_id:   [reference to contracting vehicle]
enclave:       [logical CUI enclave name]
```

Step 2: Apply labels to every CSW-managed workload

CSW UI → Inventory → Bulk Label

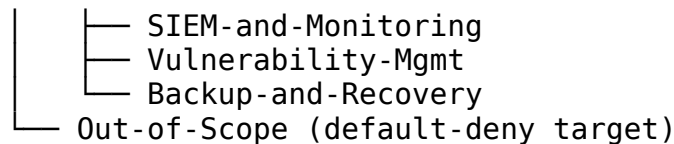
→ Mandatory for any workload supporting in-scope contracts

Step 3: Build CSW Scopes per CUI enclave

CSW UI → Organize → Scopes → New

→ Recommended hierarchy:

```
Root
├── DIB-Estate
│   ├── CUI-Enclaves
│   │   ├── Enclave-A (cui_scope=in-scope)
│   │   ├── Enclave-B (cui_scope=in-scope)
│   │   └── Enclave-N
│   ├── Security-Protection-Assets (SPA)
│   └── Identity-PKI
```



Step 4: Validate scope membership against the SSP

- Cross-check CSW count vs. SSP-documented system list
- Reconcile any delta with the CUI-handling owner before sign-off

Evidence: Per-enclave membership snapshot (CSV) with workload identity, OS, owner, CUI role, contract reference, and last-seen timestamp. This becomes the CSW companion to your SSP system inventory.

Level 1 delta: Level 1 only handles FCI; the scope is broader but the controls are simpler. Apply `cmmc_level: l1` and use the same scope structure.

Level 3 delta: Level 3 inherits all Level 2 scope; add `cmmc_level: l3` to the most-sensitive enclaves. The additional NIST 800-172 enhancements typically tighten existing controls rather than add new control families.

3. AC — Access Control

3.1 AC.L1-3.1.1 / AC.L2-3.1.1 — Limit System Access

Limit system access to authorised users, processes, and devices acting on behalf of authorised users.

CSW Implementation:

Step 1: Workload-level deny-by-default at the CUI enclave boundary

CSW UI → Defend → Segmentation → New Workspace

Name: `cmmc-{enclave-name}`

Scope: `cui_scope=in-scope AND enclave=[name]`

Step 2: Build allow-list per documented system function

- Use ADM to compute as-observed clusters
- Reject "noise" clusters; rename to system-function names
- Each cluster becomes a documented allow rule

Step 3: Run in Simulation 30+ days; resolve gaps with system owner

Step 4: Promote to Enforce; gate by change-management approval

3.2 AC.L2-3.1.3 — Control Information Flow

Control the flow of CUI in accordance with approved authorisations.

CSW Implementation:

Step 1: Enumerate observed CUI-enclave egress

CSW UI → Investigate → Flow Search

Filter: `source_scope=cui-enclaves AND destination ≠ enclave`

Step 2: Reconcile against the SSP's documented information flows
→ Observed-but-undocumented = candidate exception or violation
→ Documented-but-not-observed = candidate for SSP cleanup

Step 3: Enforce flow boundary via CSW policy
→ ALLOW only documented inter-enclave flows
→ DENY everything else with audit logging

3.3 AC.L2-3.1.20 — Verify and Control Connections to External Systems

CSW Implementation:

Step 1: Enumerate all egress from `cui_scope=in-scope` workloads
Step 2: For each external destination, verify it is documented in the SSP's external-systems register
Step 3: Egress allowlist per enclave; alert on net-new external destinations

3.4 AC.L2-3.1.22 — Control CUI on Publicly-Accessible Systems

CSW Implementation:

Step 1: Identify any `cui_scope=in-scope` workload that is also internet-reachable
→ CSW reachability query
Step 2: For each, validate that the architecture is intentional and that the workload has supporting boundary-protection evidence for SC.L2-3.13.5
Step 3: Continuous monitoring for net-new internet-reachable CUI workloads

Evidence (AC family): (a) per-enclave segmentation policy export with simulation → enforcement log; (b) information-flow reconciliation against SSP; (c) external-systems register reconciled against observed egress; (d) internet-exposure inventory.

4. AU — Audit and Accountability

4.1 AU.L2-3.3.1 — Create Audit Records

Create and retain system audit logs and records to the extent needed to enable monitoring, analysis, investigation, and reporting of unlawful or unauthorised system activity.

CSW Implementation:

Step 1: Configure SIEM forwarding for every `cui_scope=in-scope` workload
CSW UI → Manage → Data Tap → SIEM
→ Splunk HEC, QRadar, Sentinel, Cisco XDR, syslog

- Forward: per-flow records, process events, policy violations, behavioural detections, vulnerability events

Step 2: Confirm CMMC-grade audit detail

- Per-flow: source, destination, port, byte counts, timestamps, process attribution, scope context
- Per-process: command line, parent-child, file accesses, network activity
- Per-event: detection rule fired, severity, evidence

4.2 AU.L2-3.3.2 — Ensure Action Traceability

Ensure that the actions of individual system users can be uniquely traced to those users.

CSW Implementation:

- Step 1: Process telemetry includes user attribution where the OS sensor supports it
- Step 2: Pair CSW process events with identity-system events at the SIEM (CSW + AD/IdP correlation)
- Step 3: For shared-credential investigations, CSW process timeline narrows the window for identity correlation

4.3 AU.L2-3.3.4, 3.3.5, 3.3.8 — Alert Failures, Correlate, Protect Logs

CSW Implementation:

- Step 1: CSW data-tap monitor: alert on forwarder failure
- Step 2: SIEM correlation rules combining CSW + identity + endpoint telemetry
- Step 3: SIEM-side immutable log storage (CSW does not store the long-term archive; the SIEM does)

4.4 AU.L2-3.3.9 — Limit Management of Audit Logging Functionality

CSW Implementation: CSW administrative access is RBAC-controlled; configure separate roles for audit-log management vs. policy management; document in the SSP.

Evidence (AU family): (a) SIEM forwarding configuration; (b) sample audit record showing per-flow + per-process detail; (c) audit retention configuration; (d) CSW RBAC export for audit-management roles.

5. CM — Configuration Management

5.1 CM.L2-3.4.1 — Establish Configuration Baselines

Establish and maintain baseline configurations and inventories of organisational systems.

CSW Implementation:

Step 1: Capture baseline per cui_scope=in-scope workload
CSW UI → Investigate → Inventory → Workload → Software & Packages
→ Auto-captured: OS, kernel, package list, version, install date, listening ports, running processes
→ Snapshot daily to CSW data tap; this is the CMMC L2 baseline

Step 2: Schedule baseline export per enclave; route to SSP appendix

5.2 CM.L2-3.4.2 — Establish Security Configuration Settings

CSW Implementation: CSW does not configure host hardening; that's upstream (CIS Benchmarks, STIGs, vendor hardening guides). CSW *verifies* that the resulting state matches expectations through the baseline + drift report.

5.3 CM.L2-3.4.3 / 3.4.4 — Track and Approve Changes

CSW Implementation:

Step 1: Daily diff between today's baseline and yesterday's
Step 2: For each diff: package change, port change, process change
Step 3: Correlate change timestamp against change-ticket system
→ Authorised change = log + close
→ Orphan change (no ticket) = unauthorised-change candidate
→ Route to incident process

5.4 CM.L2-3.4.6 — Employ Principle of Least Functionality

CSW Implementation:

Step 1: Per-workload listening-port + service inventory
Step 2: Cross-reference against the documented baseline
→ Ports running but not in baseline = candidate for closure
→ Ports with no observed flow in 90 days = candidate for closure
Step 3: Generate quarterly "least functionality" review report

5.5 CM.L2-3.4.7 — Restrict Use of Nonessential Programs/Functions

CSW Implementation:

Step 1: Software inventory + allow-list deviation alert
Step 2: For Level 3: behavioural prevention of unauthorised executable launches

Evidence (CM family): (a) baseline export per workload; (b) daily drift log with disposition; (c) quarterly least-functionality review; (d) allow-list deviation log.

6. RA — Risk Assessment

6.1 RA.L2-3.11.1 — Conduct Risk Assessments

CSW does not conduct the formal risk assessment. CSW supplies inputs.

6.2 RA.L2-3.11.2 — Scan for Vulnerabilities

Scan for vulnerabilities in the system and applications periodically and when new vulnerabilities affecting the system are identified.

CSW Implementation:

Step 1: Continuous CVE inventory at workload level

CSW UI → Investigate → Vulnerability Report

→ Per-workload CVE list with CVSS, exploit availability, EPSS

Step 2: Filter by cui_scope=in-scope → priority remediation queue

Step 3: Schedule weekly export to CMMC evidence store

Step 4: Tie remediation progress to POA&M entries

6.3 RA.L2-3.11.3 — Remediate Vulnerabilities

CSW Implementation:

Step 1: Patch SLA per CVSS band (org-defined)

→ Common: Critical 30 days, High 60 days, Medium 90 days for
CMMC Level 2; tighter for Level 3

Step 2: For deferred patches, document compensating controls
in CSW workspace notes; reference in POA&M

Step 3: Trend report monthly; route to security leadership

Evidence (RA family): (a) per-CUI-workload CVE list dated to cadence; (b) patch SLA compliance trend; (c) compensating-control register; (d) POA&M items linked to CSW vuln IDs.

7. SC — System and Communications Protection

This is the densest CSW alignment in CMMC L2.

7.1 SC.L2-3.13.1 — Monitor, Control, and Protect Communications at System Boundaries

CSW Implementation:

Step 1: Define the CUI enclave boundary in CSW
→ Workspace per enclave; default deny across the boundary

Step 2: Allow-list documented inter-enclave flows

Step 3: Continuous monitoring + alerting on attempted boundary crossings outside the allow-list

7.2 SC.L2-3.13.2 — Employ Architectural Designs

CSW Implementation: CSW supplies the **as-observed** architecture that complements the **as-designed** architecture in your SSP network diagrams. Reconcile them; resolve any delta.

7.3 SC.L2-3.13.5 — Implement Subnetworks for Publicly-Accessible Components

CSW Implementation:

Step 1: Identify publicly-accessible components in CUI scope
(typically a small set: web frontends, partner APIs)

Step 2: Verify CSW policy puts them in their own scope

Step 3: Verify CSW policy denies all flow from those components into the deeper CUI enclave except documented paths

7.4 SC.L2-3.13.6 — Deny by Default; Permit by Exception

CSW Implementation: This is what CSW segmentation **is**. The default-deny, allow-by-exception posture is enforced at the workload identity layer; every allow rule traces back to a documented business need.

7.5 SC.L2-3.13.7 — Prevent Split Tunneling on Remote Devices

CSW Implementation: CSW reports observed flows from remote/ VPN sources; alert on flows that suggest split-tunnel behaviour (simultaneous internal + external destination from the same endpoint). Primary control is VPN configuration; CSW is the detective check.

7.6 SC.L2-3.13.16 — Protect CUI Confidentiality at Rest

CSW Implementation: Out of scope — encryption at rest is upstream. CSW *does* alert if a CUI workload exposes services not intended for its role (e.g. listening on port 80 when it should only serve port 443).

Evidence (SC family): (a) per-enclave segmentation policy export; (b) as-observed architecture diagram (ADM export); (c) public-component scope documentation; (d) split-tunnel alert log.

8. SI — System and Information Integrity

8.1 SI.L2-3.14.1 — Identify, Report, and Correct System Flaws

CSW Implementation:

Step 1: Continuous CVE inventory feeds the flaw-identification step (see RA.L2-3.11.2)

Step 2: Daily configuration baseline + drift catches integrity deviations beyond CVEs

Step 3: SIEM forwarding routes detections to the SOC for response

8.2 SI.L2-3.14.2 — Provide Protection from Malicious Code

CSW is layered with endpoint AV. CSW behavioural rules catch post-exploitation patterns (privilege escalation, lateral movement, unusual outbound) that endpoint AV may miss.

8.3 SI.L2-3.14.3 — Monitor System Security Alerts and Advisories

CSW Implementation: CSW threat intel feeds enrich CVE prioritisation; alert routing connects threat intel into the SOC workflow.

8.4 SI.L2-3.14.6 — Monitor Communications

Monitor organisational systems including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.

CSW Implementation:

Step 1: Per-workload flow telemetry forwarded to SIEM

Step 2: Behavioural rule catalogue running against telemetry

Step 3: Conversation-graph anomaly detection (new edges, port distribution shifts) alerts on indicator-class events

8.5 SI.L2-3.14.7 — Identify Unauthorised Use

CSW Implementation: Process + flow telemetry shows what's running; identity-aware policy shows who's authorised. Combination catches unauthorised use patterns at the workload tier.

Evidence (SI family): (a) detection rule catalogue; (b) sample alerts with full forensic context; (c) anomaly alert log; (d) threat-intel enrichment configuration.

9. IR — Incident Response (Evidence Side)

9.1 IR.L2-3.6.1 / 3.6.2 / 3.6.3 — IR Process

CSW does not author the IR plan. CSW supplies the forensic substrate for IR steps.

CSW Implementation — Six-Artifact Bundle:

For each incident on a CUI-scope workload:

(a) Affected workload set (CUI scope, contract reference)

(b) Time-anchored flow record (process attribution)

- (c) Process activity record
- (d) Software footprint at time of incident (CVE exposure)
- (e) Containment evidence (quarantine policy, time-to-quarantine)
- (f) Configuration baseline diff (pre vs post)

Evidence (IR family): (a) standard incident dossier template; (b) MTTD/MTTR metrics by enclave; (c) sample dossier per quarter.

10. Mapping Table — CMMC L2 (NIST 800-171) Family → CSW Capability

(Consolidated from sections 3–9; only CSW-relevant practices shown)

Practice	Topic	CSW capability
AC.L1/L2-3.1.1	Limit system access	Workload-level deny-by-default segmentation
AC.L2-3.1.3	Control CUI flow	Inter-enclave flow allow-list + reconciliation
AC.L2-3.1.20	Verify external connections	Egress allowlist + alert on net-new
AC.L2-3.1.22	CUI on publicly-accessible systems	Internet-reachability query + scope review
AU.L2-3.3.1	Audit records	Per-flow + per-process telemetry to SIEM
AU.L2-3.3.2	Action traceability	Process attribution + identity correlation at SIEM
AU.L2-3.3.4/5/8	Alert / correlate / protect logs	Forwarder health alert + SIEM correlation
AU.L2-3.3.9	Limit audit-log mgmt	CSW RBAC for audit-mgmt roles
CM.L2-3.4.1	Baseline configurations	Daily snapshot per workload
CM.L2-3.4.3/4	Track and approve changes	Daily diff + change-ticket attribution
CM.L2-3.4.6	Least functionality	Listening-port + service inventory + 90-day-no-flow review
CM.L2-3.4.7	Restrict nonessential programs	Software allow-list + (L3) behavioural block
RA.L2-3.11.2	Vulnerability scanning	Continuous CVE

Practice	Topic	CSW capability
RA.L2-3.11.3	Remediate vulnerabilities	inventory per workload Patch SLA tracking + compensating-control register + POA&M linkage
SC.L2-3.13.1	Boundary protection	Per-enclave segmentation enforcement
SC.L2-3.13.2	Architectural designs	ADM-derived as-observed architecture
SC.L2-3.13.5	Subnetworks for public components	Public-component scope isolation
SC.L2-3.13.6	Deny by default	Workload-level deny-by-default (native)
SC.L2-3.13.7	Prevent split tunneling	Detective alert on split-tunnel patterns
SI.L2-3.14.1	Identify and correct flaws	CVE inventory + drift + SIEM routing
SI.L2-3.14.2	Malicious code protection	Behavioural rules layered with endpoint AV
SI.L2-3.14.3	Monitor security advisories	Threat-intel feeds enrich CVE prioritisation
SI.L2-3.14.6	Monitor communications	Flow telemetry + behavioural rules + anomaly detection
SI.L2-3.14.7	Identify unauthorised use	Process telemetry + identity-aware policy
IR.L2-3.6.x	Incident response	Six-artefact dossier per CUI-scope incident

11. Level 1 (FCI) Delta

Level 1 implements 15 basic safeguarding requirements from FAR 52.204-21 (which are themselves derived from a small subset of NIST 800-171). Level 1 is annual self-attestation; no C3PAO.

CSW's Level 1 contribution:

FAR 52.204-21 (b)(1) clause	CSW capability
(i) Limit system access to authorised	Workload-level segmentation

FAR 52.204-21 (b)(1) clause	CSW capability
users	
(ii) Limit access to types of transactions / functions	Allow-list per documented function
(iii) Verify and control external connections	Egress allowlist
(iv) Control information posted on publicly-accessible systems	Internet-reachability inventory
(v) Identify users / processes / devices	Sensor + cloud connector inventory
(vi) Authenticate users	(Out of scope — identity upstream)
(vii) Sanitise / destroy media	(Out of scope)
(viii) Limit physical access	(Out of scope)
(ix) Escort visitors / monitor	(Out of scope)
(x) Audit physical access	(Out of scope)
(xi) Maintain audit logs	SIEM forwarding
(xii) Identify / report / correct flaws timely	CVE inventory + remediation tracking
(xiii) Provide protection from malicious code	Behavioural rules
(xiv) Update malicious code mechanisms	(Endpoint AV upstream; CSW threat intel feeds CVE)
(xv) Periodic system / real-time scans	Continuous CVE + flow telemetry

12. Level 3 Delta

Level 3 inherits Level 2 plus selected NIST 800-172 enhanced security requirements addressing Advanced Persistent Threats. The additions tighten existing practices rather than add new families.

CSW's Level 3 contribution highlights:

Practice area	Level 3 enhancement	CSW capability
3.4.2e	Employ automated mechanisms to detect misconfigurations	Daily drift report with automated escalation
3.11.1e	Threat-aware risk assessments	Threat-intel-enriched CVE prioritisation
3.13.4e	Employ physical / logical isolation	Tighter per-enclave segmentation; identity-aware allow rules
3.14.1e	Verify integrity of	Software inventory diff

Practice area	Level 3 enhancement	CSW capability
	security-critical software	+ behavioural integrity checks
3.14.6e	Use threat hunting and indicators	Behavioural rules + conversation-graph anomalies + threat-intel hunting queries
3.14.7e	Establish + maintain threat-modelling	ADM dependency graph as input to threat-modelling

13. C3PAO Assessor Response Guide

When a C3PAO asks for evidence at Level 2 assessment:

Assessor asks	You provide
"Show your CUI scope and the systems supporting it"	Per-enclave inventory CSV with <code>cui_scope</code> , <code>cui_role</code> , <code>contract_id</code> labels
"Demonstrate AC.L2-3.1.1 access enforcement"	Per-enclave segmentation workspace export + simulation → enforcement log
"Provide AC.L2-3.1.3 information flow control"	Inter-enclave flow allow-list + reconciliation against SSP
"Show AU.L2-3.3.1/3.3.2 audit records and traceability"	SIEM forwarding configuration + sample audit record with process + identity attribution
"Demonstrate CM.L2-3.4.1 baseline configurations"	Daily baseline export per workload + diff log
"Provide RA.L2-3.11.2 vulnerability scan evidence"	Per-CUI-workload CVE list dated to scan cadence
"Show RA.L2-3.11.3 remediation tracking"	POA&M items linked to CSW vuln IDs + patch SLA compliance trend
"Demonstrate SC.L2-3.13.6 deny-by-default"	Per-enclave segmentation policy export with deny-default + documented exceptions
"Provide SI.L2-3.14.6 monitoring evidence"	Behavioural rule catalogue + sample alerts with forensic context
"Reconstruct the timeline for incident X"	Six-artefact incident dossier (§9)

14. Related Frameworks

CMMC 2.0 inherits heavily from NIST and from the CSF / CIS layered view:

- **NIST SP 800-171 Rev 2** — CMMC Level 2 IS NIST 800-171. Read this reference design for L2 work.
 - **NIST SP 800-172** — CMMC Level 3 enhanced controls source. CSW capabilities for L3 are noted in §12 above.
 - **NIST SP 800-53 Rev 5** — superset of 800-171. The 800-53 reference design covers CMMC L2 with broader context. See [800-53 reference design](#).
 - **NIST SP 800-207 (Zero Trust Architecture)** — an architectural pattern that can support many SC/AC control objectives at depth. See [800-207 reference design](#).
 - **NIST CSF 2.0** — the outcomes wrapper that cites 800-171 as Informative References under PR/DE/RS Subcategories. See [CSF reference design](#).
 - **CIS Controls v8.1** — many CIS Safeguards align directly with 800-171 practices. See [CIS reference design](#).
 - **DFARS 252.204-7012** — the contractual basis for CMMC; the technical content sits in NIST 800-171 which this reference design addresses.
-

15. Disclaimer

This reference design is **draft v1** describing how Cisco Secure Workload capabilities can support a CMMC 2.0 programme at Level 2 (with Level 1 and Level 3 deltas). It is **not** legal or compliance advice and does not constitute a finding of compliance.

Specifically:

- The DoD publishes the authoritative CMMC 2.0 text at <https://dodcio.defense.gov/CMMC/>. The DCMA Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) and the Cyber AB publish authoritative assessment guidance. Always validate against the **current effective rule** (DFARS 252.204-7021 / 32 CFR Part 170) and against any DoD class deviations.
- CMMC Level 2 assessment is performed by a Certified Third-Party Assessor Organisation (C3PAO) or, for limited contracts, by self-assessment. Nothing in this reference design substitutes for the SSP, POA&M, or the C3PAO engagement.
- Mapping a CSW capability to a 800-171 practice does not by itself satisfy the practice. The C3PAO will look for a documented process, evidence cadence, and management review behind the technical implementation. CSW supplies the technical evidence; the SSP and POA&M document the process around it.
- CSW does not address AT, MP, PE, or PS families. Reference your HR, media-handling, physical-protection, and personnel-security programmes for those.

This document should receive subject-matter-expert review for both CMMC 2.0 currency (the rule and assessment guidance evolve) and current Cisco product capability before being relied upon in a formal compliance engagement.